

ApoloCiber

Relatório de Análise de Vulnerabilidades e Maturidade Cibernética

Metodologia: Framework Cis Controls v8 (Níveis G1 e G2)

Auditor Responsável: José Apolo Marques Nascimento – Especialista Certificado em Segurança Cibernética (ENAP)

Nome do Cliente: **Confidencial**

Data de Avaliação: 24/04/2026

Data de Emissão: 26/04/2026

Sumário

01. Introdução	1
02. Objetivo	2
03. Escopo	3
04. Metodologia	4
05. Ambiente Avaliado, Ferramenta Utilizada	5
06. Controle de Versões	6
07. Disclaimer	7
08. Relatório Executivo	8
09. Estatísticas	9
10. Estatísticas de Criticidade	10
11. Análise de Portas Abertas	11
11.1 445/tcp (SMB)	
11.2 139/tcp (NetBIOS)	
11.3 135/tcp (RPC)	
11.4 2179/tcp (VM RDP – Hyper-V)	
11.5 16992/tcp (Intel AMT)	
12. Análise de Portas Abertas – Continuação	12
13. Resumo Quantitativo.....	13
14. Distribuição por Origem	14
15. Conclusão de Análise de Portas Abertas e Rede Local.....	15
16. Recomendações – Mitigações de Vulnerabilidades	16
17. Relatório Técnico	17
18. Relatório Técnico - Continuação	18
19. Riscos Identificados.....	19
20. Funcionamento e Impacto de Portas Abertas.....	20
21. Conclusão Final.....	21
22. Evidências Técnicas.....	22
22.1 Continuação da Pagina 22	22.1
23. Portas Abertas	23
24. Evidências de Rede Com Configurações Padrão – Baixa Segurança	24
24.1 Continuação da Pagina 24	24.1

Introdução

Com o aumento constante das ameaças cibernéticas, a identificação e mitigação de vulnerabilidades tornaram-se atividades essenciais para a proteção de sistemas e redes. Ambientes baseados em sistema operacional Windows, quando conectados a redes locais, podem apresentar diversas fragilidades, especialmente quando há exposição de serviços e configurações inadequadas.

Neste contexto, a análise de vulnerabilidades tem como finalidade identificar falhas de segurança que possam ser exploradas por agentes maliciosos, comprometendo a confidencialidade, integridade e disponibilidade das informações. Entre os principais pontos de atenção estão as portas abertas associadas a serviços críticos, bem como a configuração de dispositivos de rede, como roteadores.

O presente relatório apresenta os resultados de uma análise de vulnerabilidades realizada em um ambiente Windows e rede local (LAN), com foco na identificação de serviços expostos, falhas de configuração e riscos associados. A avaliação foi conduzida com base nos princípios dos CIS Critical Security Controls (CIS Controls), reconhecidos como boas práticas para fortalecimento da segurança da informação.

A partir dos achados identificados, são apresentadas análises técnicas, classificação de criticidade, riscos envolvidos e recomendações para mitigação, com o objetivo de contribuir para a melhoria da postura de segurança do ambiente avaliado.

Objetivo

O presente relatório tem como objetivo realizar uma análise de vulnerabilidades em um ambiente composto por sistema operacional Windows e rede local (LAN), com a finalidade de identificar fragilidades relacionadas à exposição de serviços, configurações inadequadas e controles de segurança.

A análise busca avaliar a presença de portas abertas, serviços ativos e possíveis falhas na configuração do roteador, bem como verificar aspectos de controle de acessos, atualização de sistemas e proteção da rede.

Este trabalho está fundamentado nos princípios dos CIS Critical Security Controls (CIS Controls), com foco na identificação de riscos associados à Configuração Segura (CIS 4), Controle de Acessos (CIS 5 e 6), Gestão de Vulnerabilidades (CIS 7) e Segurança de Rede (CIS 12).

Como resultado, o objetivo é fornecer uma visão clara do nível de exposição do ambiente, permitindo a proposição de recomendações para mitigação das vulnerabilidades identificadas e melhoria da postura de segurança.

Escopo

Este relatório tem como escopo a realização de uma análise de vulnerabilidades em um ambiente composto por uma estação com sistema operacional Windows e uma rede local (LAN) conectada por meio de um roteador.

A avaliação contempla a identificação de portas abertas, serviços expostos, configurações de segurança do sistema Windows, bem como a análise das configurações do roteador, incluindo parâmetros de acesso, exposição de serviços e nível de proteção da rede. Também foram considerados aspectos relacionados ao controle de acessos, atualização de sistemas e visibilidade de eventos de segurança.

A análise foi conduzida com base nos princípios dos CIS Critical Security Controls (CIS Controls), com foco nos controles de Gestão de Ativos (CIS 1 e 2), Configuração Segura (CIS 4), Controle de Acessos (CIS 5 e 6), Gestão de Vulnerabilidades (CIS 7), Monitoramento e Auditoria (CIS 8) e Segurança de Rede (CIS 12).

Este escopo está limitado à identificação de vulnerabilidades técnicas e de configuração, não incluindo testes intrusivos avançados, exploração ativa de falhas ou simulações completas de ataque. A análise reflete o estado do ambiente no momento da avaliação, podendo sofrer alterações conforme mudanças posteriores na infraestrutura.

Metodologia

A análise de vulnerabilidades foi conduzida com base nas boas práticas de segurança da informação e nos princípios dos CIS Critical Security Controls (CIS Controls), com foco na identificação de fragilidades em sistemas Windows e na rede local (LAN).

O processo iniciou-se com a utilização da ferramenta Nmap, empregada para realizar a varredura de portas e identificação de serviços ativos no ambiente analisado. Essa etapa teve como objetivo mapear a superfície de ataque, identificando portas abertas e possíveis pontos de exposição.

Em seguida, foi realizada a análise dos serviços identificados, considerando seus riscos potenciais, nível de criticidade e possibilidade de exploração. Foram avaliados serviços críticos como SMB, NetBIOS, RPC, RDP (Hyper-V) e Intel AMT, com base em vulnerabilidades conhecidas e boas práticas de segurança.

Paralelamente, foi conduzida uma verificação das configurações do sistema operacional Windows, incluindo aspectos relacionados a atualizações de segurança, controle de acessos e exposição de serviços. Também foi analisada a configuração do roteador da rede local, com foco na identificação de configurações padrão, exposição de portas e ausência de controles de segurança.

Os resultados obtidos foram correlacionados com os controles do CIS, especialmente Configuração Segura (CIS 4), Controle de Acessos (CIS 5 e 6), Gestão de Vulnerabilidades (CIS 7), Monitoramento e Auditoria (CIS 8) e Segurança de Rede (CIS 12), permitindo a classificação das vulnerabilidades e a identificação das principais lacunas de segurança.

Por fim, os achados foram organizados e documentados de forma estruturada, incluindo análise de criticidade, riscos associados e recomendações para mitigação, visando apoiar a melhoria da postura de segurança do ambiente avaliado.

Ambiente Avaliado

O ambiente avaliado consiste em uma estação de trabalho com sistema operacional Windows conectada a uma rede local (LAN) por meio de um roteador. Trata-se de um cenário típico de pequeno porte, no qual os dispositivos compartilham recursos de rede e acesso à internet, sem a presença de controles avançados de segurança.

A análise considerou aspectos relacionados ao sistema Windows, incluindo serviços ativos, portas abertas, configurações de segurança, controle de usuários e estado de atualização do sistema. Foram identificados serviços expostos como SMB, NetBIOS, RPC, RDP (Hyper-V) e Intel AMT, que, quando não devidamente controlados, podem representar riscos à segurança do ambiente.

No âmbito da rede local, foram avaliadas as configurações do roteador, incluindo parâmetros de acesso, exposição de portas e nível de proteção da rede. Observou-se a utilização de configurações padrão e ausência de mecanismos adequados de restrição e monitoramento, o que contribui para o aumento da superfície de ataque.

A avaliação foi conduzida com base nos princípios dos CIS Critical Security Controls (CIS Controls), contemplando principalmente os domínios de Gestão de Ativos (CIS 1 e 2), Configuração Segura (CIS 4), Controle de Acessos (CIS 5 e 6), Gestão de Vulnerabilidades (CIS 7), Monitoramento e Auditoria (CIS 8) e Segurança de Rede (CIS 12).

O escopo do ambiente avaliado está restrito à estação Windows e à infraestrutura de rede local, não incluindo integrações com ambientes externos complexos. Ainda assim, os elementos analisados representam um cenário comum, onde a ausência de controles básicos pode resultar em vulnerabilidades relevantes.

Ferramenta Utilizada

A ferramenta Nmap (Network Mapper) foi utilizada para a realização da varredura de rede, permitindo a identificação de portas abertas, serviços ativos e possíveis pontos de exposição no ambiente analisado. O Nmap é amplamente reconhecido por sua eficiência e precisão na descoberta de ativos e mapeamento da superfície de ataque.

Como principal benefício, a ferramenta possibilita uma visão detalhada dos serviços em execução, auxiliando na detecção de vulnerabilidades e na identificação de configurações inadequadas. Dessa forma, contribui diretamente para a análise de segurança e tomada de decisões voltadas à mitigação de riscos.

OpenVAS / GVM (Greenbone Vulnerability Management)

Ferramenta empregada para execução de análises de vulnerabilidades em ambientes laboratoriais, permitindo identificação de falhas de segurança, serviços expostos, vulnerabilidades conhecidas (CVEs) e validação de controles aplicados durante processos de hardening e fortalecimento de infraestrutura.

Controle de Versão

Versão	Data	Responsável	Descrição da Alteração	Status
1.0	24/04/2026	Apolo Marques	Criação inicial do relatório	Elaborado
1.1	24/04/2026	Apolo Marques	Inclusão da análise do sistema Windows	Revisado
1.2	24/04/2026	Apolo Marques	Inclusão da análise da rede local (roteador)	Revisado
1.3	24/04/2026	Apolo Marques	Ajustes conforme princípios do CIS Controls	Revisado
2.0	26/04/2026	Apolo Marques	Versão final do relatório	Aprovado

Disclaimer

Este relatório de análise de vulnerabilidades foi elaborado com base nas boas práticas de segurança da informação, tomando como referência os princípios dos CIS Critical Security Controls (CIS Controls). As atividades realizadas tiveram como objetivo identificar fragilidades técnicas e de configuração no ambiente avaliado, sem a intenção de explorar ou causar qualquer impacto operacional.

A análise foi conduzida dentro de um escopo previamente definido, considerando um ponto específico no tempo. Dessa forma, os resultados apresentados refletem exclusivamente as condições observadas durante o período da avaliação, podendo não representar o estado atual do ambiente após alterações, atualizações ou correções realizadas posteriormente.

Os achados e recomendações descritos neste documento estão alinhados a controles como Gestão de Ativos (CIS 1 e 2), Configuração Segura (CIS 4), Controle de Acessos (CIS 5 e 6), Gestão de Vulnerabilidades (CIS 7) e Segurança de Rede (CIS 12). No entanto, a implementação dessas recomendações depende de fatores organizacionais, técnicos e operacionais que não fazem parte do escopo desta análise.

Este relatório não garante a identificação de todas as vulnerabilidades existentes, uma vez que novas ameaças podem surgir continuamente, conforme destacado pelos princípios de melhoria contínua dos CIS Controls. Além disso, a exploração de vulnerabilidades não foi realizada além do necessário para validação técnica, respeitando limites éticos e operacionais.

As informações aqui contidas são confidenciais e destinam-se exclusivamente aos responsáveis pelo ambiente avaliado. O uso indevido, a reprodução ou a divulgação não autorizada deste documento não são recomendados.

Por fim, a responsabilidade pela aplicação das correções, implementação dos controles de segurança e gestão contínua dos riscos permanece sob responsabilidade da organização avaliada.

Relatório Executivo

Objetivo

Este trabalho tem como objetivo realizar uma análise de vulnerabilidades em uma estação com sistema operacional Windows e na rede local associada, identificando possíveis fragilidades que possam comprometer a segurança dos ativos e das informações.

A avaliação é orientada pelos princípios dos CIS Critical Security Controls (CIS Controls), com foco na identificação de riscos relacionados à gestão de ativos, configuração segura, controle de acessos, exposição de serviços e monitoramento do ambiente.

Escopo

A análise contempla os seguintes componentes:

Sistema Windows:

Avaliação de configurações de segurança, atualização do sistema, controle de usuários e exposição de serviços, alinhada aos controles de Gestão de Vulnerabilidades (CIS 7), Controle de Acessos (CIS 5 e 6) e Configuração Segura (CIS 4)

Rede Local (LAN):

Verificação das configurações do roteador, identificação de portas abertas, controle de dispositivos conectados e aspectos de segmentação de rede, em conformidade com Gestão de Ativos (CIS 1 e 2) e Segurança de Rede (CIS 12)

Monitoramento e Registro:

Análise da capacidade de coleta e acompanhamento de eventos de segurança, conforme Monitoramento e Auditoria (CIS 8)

Considerações

O escopo está limitado à identificação de vulnerabilidades técnicas e de configuração no ambiente analisado, não incluindo testes intrusivos avançados ou simulações completas de ataque.

Conclusão

A definição clara de objetivo e escopo, alinhada aos princípios dos CIS Controls, garante que a análise seja direcionada, consistente e focada na identificação dos principais riscos de segurança do ambiente Windows e na rede local.

Recursos tecnológicos fornecidos para análise:

Ativos inclusos: Endereço de IPv4= **Confidencial**

Ativos excluídos: Sem ativos excluídos.

Datas: A análise feita nos ativos a cima mencionados foi realizada entre as seguintes datas: 14/04/2026 a 26/04/2026.

Classificação Geral de Risco: ALTO

Estatísticas

Estatísticas de Análise de Vulnerabilidades:

A análise de vulnerabilidades realizada no ambiente Windows e na rede local permitiu identificar padrões relevantes de exposição, considerando os princípios dos CIS Critical Security Controls (CIS Controls). As estatísticas a seguir consolidam os principais achados, com foco em visibilidade, configuração segura e gestão contínua de riscos.

Principais Indicadores

Ativos identificados: A maior parte dos dispositivos conectados foi mapeada, porém ainda existem ativos sem controle completo, em desacordo com os princípios de Gestão de Ativos (CIS 1 e 2)

Portas abertas: Foram identificadas portas abertas em serviços não essenciais, aumentando a superfície de ataque, conforme abordado em Segurança de Rede (CIS 12)

Configurações padrão: Parte dos equipamentos de rede, como roteadores, apresentou configurações padrão ou pouco restritivas, em desacordo com Configuração Segura (CIS 4)

Atualizações de sistemas: Foi observado um percentual relevante de sistemas Windows sem atualizações recentes, impactando a Gestão de Vulnerabilidades (CIS 7)

Controle de acessos: Identificou-se uso de credenciais simples e ausência de autenticação multifator em diversos pontos, contrariando os princípios de Controle de Acessos (CIS 5 e 6)

Monitoramento: A capacidade de coleta e análise de logs ainda é limitada, reduzindo a efetividade de Monitoramento e Auditoria (CIS 8)

Análise Consolidada

Os dados indicam que as vulnerabilidades identificadas estão concentradas principalmente em falhas de configuração, exposição desnecessária de serviços e ausência de controles básicos de segurança. Esses fatores estão diretamente relacionados à não adoção plena dos controles fundamentais do CIS, especialmente aqueles voltados à proteção de rede, gestão de ativos e controle de acessos.

Conclusão

As estatísticas demonstram a necessidade de evolução na maturidade de segurança do ambiente. A adoção consistente dos princípios dos CIS Controls permitirá melhorar os indicadores apresentados, reduzir a superfície de ataque e aumentar a capacidade de prevenção e resposta a incidentes.

Estatísticas de Criticidade – Análise de Vulnerabilidades

Ambiente Windows e Rede Local (LAN)

Nível de Criticidade	Quantidade	Vulnerabilidades Identificadas	Controles Cis Relacionados
Crítico	3	Porta 445 (SMB), Porta 16992 (Intel AMT), Roteador com configuração insegura	CIS 4, CIS 5, CIS 7, CIS 12
Alta	3	Porta 139 (NetBIOS), Porta 135 (RPC), Porta 2179 (VM RDP)	CIS 4, CIS 5, CIS 6, CIS 12
Média	0	Não identificado	-
Baixa	0	Não identificado	-
Informativa	0	Não identificado	CIS 1, CIS 2

Análise de Portas Abertas – Ambiente Windows

11.1 Porta 445/tcp – SMB (Microsoft-DS)

Criticidade: Crítica

Descrição: Protocolo de compartilhamento de arquivos do Windows utilizado para acesso pastas e recursos na rede

Riscos:

Execução remota de código (ex: ataques como WannaCry)

Movimentação lateral dentro da rede

Acesso não autorizado a arquivos sensíveis

Disseminação de malware e ransomware

CIS Relacionado: CIS 4, CIS 7, CIS 12

11.2 Porta 139/tcp – NetBIOS Session Service

Criticidade: Alta

Descrição: Serviço utilizado para comunicação e compartilhamento de recursos via NetBIOS em redes Windows

Riscos:

Enumeração de usuários e compartilhamentos

Exposição de informações da rede

Acesso indevido a arquivos

Vetor para ataques internos

CIS Relacionado: CIS 4, CIS 5, CIS 12

11.3 Porta 135/tcp – MSRPC (Microsoft Remote Procedure Call)

Criticidade: Alta

Descrição: Serviço responsável pela comunicação entre processos e serviços no ambiente Windows

Riscos:

Enumeração de serviços e processos

Exploração de vulnerabilidades em serviços RPC

Base para ataques mais avançados

CIS Relacionado: CIS 4, CIS 7

11.4 Porta 2179/tcp – VM RDP (Hyper-V)

Criticidade: Alta

Descrição: Serviço de acesso remoto a máquinas virtuais em ambientes Hyper-V

Riscos:

Acesso remoto não autorizado

Ataques de força bruta

Comprometimento de máquinas virtuais

CIS Relacionado: CIS 5, CIS 6, CIS 12

11.5 Porta 16992/tcp – Intel AMT (HTTP)

Criticidade: Crítica

Descrição: Interface de gerenciamento remoto em nível de firmware (Intel Active Management Technology)

Riscos:

Controle remoto total da máquina

Acesso mesmo com o sistema desligado

Exploração de falhas de autenticação

Comprometimento completo do dispositivo

CIS Relacionado: CIS 4, CIS 5, CIS 7, CIS 12

Vulnerabilidade – Rede Local (Roteador Mal Configurado)

Criticidade: Crítica

Descrição: Roteador com configurações padrão e ausência de controles de segurança adequados

Riscos:

Acesso não autorizado à rede Wi-Fi

Exposição de portas para a internet

Interceptação de tráfego de rede

Possibilidade de ataques internos e externos

Comprometimento de todos os dispositivos conectados

CIS Relacionado: CIS 4, CIS 12, CIS 1, CIS 2

Resumo Quantitativo

Nível de Criticidade	Quantidade	Percentual
Crítico	3	50%
Alto	3	50%
Médio	0	0%
Baixo	0	0%
Total	6	100%

Resumo Quantitativo

Os dados indicam que 100% das vulnerabilidades estão classificadas como Críticas e Altas, evidenciando elevada exposição do ambiente. As falhas estão concentradas principalmente em serviços expostos no Windows e em configurações inadequadas da rede local, aumentando o risco de acesso não autorizado e comprometimento do sistema.

Esse cenário demonstra a necessidade de aplicação dos controles de Configuração Segura (CIS 4), Gestão de Vulnerabilidades (CIS 7) e Segurança de Rede (CIS 12) para redução dos riscos identificados.

Distribuição por Origem

Origem da Vulnerabilidade	Quantidade	Principais Problemas Identificados	CIS Controls Relacionados
Sistema Windows	5	Portas abertas (SMB, RPC, NetBIOS, RDP, AMT)	CIS 4, CIS 5, CIS 6, CIS 7
Rede Local (Roteador / LAN)	1	Configuração padrão e falhas de segurança	CIS 4, CIS 12

Análise Resumida

Os dados demonstram uma alta concentração de vulnerabilidades críticas e altas, indicando exposição significativa do ambiente. A presença de serviços sensíveis expostos, como SMB e AMT, aliada a falhas na configuração da rede local, evidencia a necessidade de aplicação dos controles de Configuração Segura (CIS 4) e Segurança de Rede (CIS 12).

Adicionalmente, lacunas em Gestão de Vulnerabilidades (CIS 7) e Controle de Acessos (CIS 5 e 6) contribuem para o aumento do risco, especialmente em cenários de exploração automatizada.

Conclusão da Análise de Portas Abertas e Rede Local

A análise realizada identificou a presença de múltiplas portas abertas associadas a serviços críticos no ambiente Windows, bem como falhas relevantes na configuração da rede local. A exposição de serviços como SMB, RPC, NetBIOS, RDP e Intel AMT, combinada com um roteador configurado de forma inadequada, amplia significativamente a superfície de ataque do ambiente.

Esse cenário facilita a exploração por agentes maliciosos, podendo resultar em acesso não autorizado, movimentação lateral entre dispositivos, comprometimento de sistemas e exposição de dados sensíveis. A ausência de controles adequados agrava ainda mais o risco, especialmente quando associada a serviços amplamente conhecidos e frequentemente explorados.

Sob a perspectiva dos CIS Critical Security Controls (CIS Controls), observa-se a necessidade de fortalecimento dos controles de Configuração Segura (CIS 4), Controle de Acessos (CIS 5 e 6), Gestão de Vulnerabilidades (CIS 7) e Segurança de Rede (CIS 12), fundamentais para a redução da exposição identificada.

Conclui-se que a combinação de portas abertas com falhas na configuração da rede local representa um risco significativo ao ambiente, exigindo a adoção de medidas corretivas imediatas para reduzir a superfície de ataque e fortalecer a segurança dos sistemas e da infraestrutura de rede.

Recomendações – Mitigação de Vulnerabilidades

Com base na análise realizada no ambiente Windows e na rede local, recomenda-se a adoção de medidas imediatas para mitigação das vulnerabilidades identificadas, em conformidade com os princípios dos CIS Critical Security Controls (CIS Controls).

Inicialmente, é fundamental reduzir a exposição de serviços, realizando o fechamento das portas não essenciais, especialmente aquelas associadas a SMB (445), NetBIOS (139) e RPC (135). Quando o uso for necessário, deve-se restringir o acesso por meio de firewall e limitar conexões apenas a hosts confiáveis, conforme os controles de Configuração Segura (CIS 4) e Segurança de Rede (CIS 12).

No caso de serviços sensíveis como Intel AMT (16992) e acesso remoto (RDP/Hyper-V), recomenda-se desabilitar quando não utilizados ou implementar controles rigorosos de autenticação e restrição de acesso, incluindo o uso de autenticação multifator (MFA), em alinhamento com Controle de Acessos (CIS 5 e 6).

É essencial também corrigir as configurações do roteador, substituindo credenciais padrão, desativando serviços desnecessários, atualizando o firmware e evitando a exposição direta de portas para a internet. A segmentação da rede (ex.: rede separada para convidados) deve ser considerada para reduzir riscos de movimentação lateral conforme CIS 4 e CIS 12.

No ambiente Windows, deve-se garantir a aplicação contínua de atualizações de segurança, reduzindo a exposição a vulnerabilidades conhecidas, conforme a Gestão de Vulnerabilidades (CIS 7). Além disso, recomenda-se revisar e limitar privilégios de usuários, adotando o princípio do menor privilégio.

Por fim, é importante implementar mecanismos de monitoramento e registro de eventos, permitindo a detecção de acessos suspeitos e resposta a incidentes, conforme CIS (Monitoramento e Auditoria).

A adoção dessas medidas contribuirá diretamente para a redução da superfície de ataque, mitigação dos riscos identificados e fortalecimento da segurança do ambiente, em conformidade com as boas práticas recomendadas pelos CIS Controls.

Relatório Técnico – Análise de Vulnerabilidades

Ambiente Windows e Rede Local (LAN)

1. Introdução

Este relatório técnico apresenta os resultados da análise de vulnerabilidades realizada em um ambiente composto por sistema operacional Windows e rede local (LAN). A avaliação teve como objetivo identificar falhas de segurança relacionadas à exposição de serviços, configurações inadequadas controles de acesso, com base nos princípios dos CIS Critical Security Controls (CIS Controls).

2. Metodologia

A análise foi conduzida utilizando técnicas de varredura de rede e inspeção de configurações, incluindo:

Identificação de portas abertas e serviços ativos por meio de ferramentas de análise (ex.: Nmap)

Avaliação de configurações do sistema Windows

Verificação das configurações do roteador da rede local

Análise de controles de acesso e exposição de serviços

Os resultados foram correlacionados com os controles do CIS para identificação de lacunas de segurança.

3. Escopo

O escopo da análise incluiu:

Estação com sistema operacional Windows

Serviços expostos na rede (portas abertas)

Infraestrutura de rede local (roteador e conectividade LAN)

4. Achados Técnicos

4.1 Portas Abertas e Serviços Expostos

Foram identificadas portas abertas associadas a serviços críticos, como:

445/tcp (SMB)

139/tcp (NetBIOS)

135/tcp (RPC)

2179/tcp (VM RDP – Hyper-V)

16992/tcp (Intel AMT)

Esses serviços, quando expostos sem controles adequados, aumentam a superfície de ataque e podem ser explorados por ameaças conhecidas.

CIS Relacionado: Configuração Segura (CIS 4), Gestão de Vulnerabilidades (CIS 7), Segurança de Rede (CIS 12)

4.2 Configuração Inadequada da Rede Local

O roteador da rede local apresentou configurações inseguras, incluindo uso de parâmetros padrão e ausência de restrições de acesso.

Risco: acesso não autorizado, interceptação de tráfego e exposição de dispositivos internos

CIS Relacionado: Configuração Segura (CIS 4), Segurança de Rede (CIS 12), Gestão de Ativos (CIS 1 e 2)

4.3 Controle de Acessos

Foram observadas fragilidades relacionadas ao uso de credenciais e ausência de mecanismos adicionais de autenticação.

Risco: comprometimento de contas e acesso indevido

CIS Relacionado: Controle de Acessos (CIS 5 e 6)

4.4 Atualizações e Gestão de Vulnerabilidades

Foram identificadas oportunidades de melhoria na aplicação de atualizações de segurança no sistema Windows.

Risco: exploração de vulnerabilidades conhecidas

CIS Relacionado: Gestão de Vulnerabilidades (CIS 7)

4.5 Monitoramento e Auditoria

Não foram identificados mecanismos eficazes de monitoramento e registro de eventos.

Risco: dificuldade na detecção de incidentes de segurança

CIS Relacionado: Monitoramento e Auditoria (CIS 8)

5. Análise Técnica

Os achados indicam que o ambiente apresenta vulnerabilidades concentradas principalmente na exposição de serviços e na configuração inadequada da rede local. A combinação de portas abertas com falhas no roteador potencializa os riscos, permitindo que um atacante explore o ambiente de forma progressiva, desde o acesso inicial até o comprometimento completo.

6. Conclusão Técnica

O ambiente analisado apresenta vulnerabilidades relevantes que podem ser exploradas com baixo nível de complexidade, especialmente na ausência de controles básicos de segurança. A adoção dos princípios dos CIS Controls, com foco em configuração segura, controle de acessos e segurança de rede, é essencial para mitigar os riscos identificados e fortalecer a proteção do ambiente.

Riscos Identificados

A análise de vulnerabilidades realizada no ambiente Windows e na rede local evidenciou riscos significativos decorrentes da exposição de serviços e de falhas na configuração da infraestrutura de rede. A presença de portas abertas associadas a serviços críticos, como SMB, RPC, NetBIOS, RDP (Hyper-V) e Intel AMT, amplia a superfície de ataque e possibilita a exploração por agentes maliciosos.

Do ponto de vista dos CIS Critical Security Controls (CIS Controls), essas fragilidades indicam deficiências principalmente nos controles de Configuração Segura (CIS 4) e Segurança de Rede (CIS 12), permitindo que serviços sensíveis fiquem acessíveis sem as devidas restrições. Esse cenário pode resultar em acesso não autorizado, execução remota de código e comprometimento total dos sistemas.

Adicionalmente, a configuração inadequada do roteador da rede local, incluindo uso de parâmetros padrão e ausência de controles de acesso, aumenta o risco de invasão da rede, interceptação de tráfego e exposição de dispositivos internos. Essa condição, associada à falta de segmentação da rede, favorece a movimentação lateral entre dispositivos comprometidos.

Foram também identificadas lacunas relacionadas à Gestão de Vulnerabilidades (CIS 7), evidenciadas pela ausência de atualizações regulares no sistema Windows, o que pode permitir a exploração de falhas conhecidas. No âmbito de Controle de Acessos (CIS 5 e 6), o uso de credenciais simples ou pouco protegidas eleva o risco de comprometimento de contas e escalonamento de privilégios.

A ausência de mecanismos adequados de Monitoramento e Auditoria (CIS 8) agrava o cenário, dificultando a detecção de atividades suspeitas e aumentando o tempo de permanência de um possível invasor no ambiente.

De forma geral, os riscos identificados podem resultar em impactos como comprometimento de dados, interrupção de serviços, acesso indevido a informações sensíveis e propagação de ataques dentro da rede local. A não aplicação dos controles básicos recomendados pelos CIS Controls contribui diretamente para o aumento da exposição e da probabilidade de incidentes de segurança.

Funcionamento e Impactos de Portas Abertas

Em ambientes Windows conectados a uma rede local, as portas de comunicação são utilizadas por serviços e aplicações para permitir a troca de dados entre dispositivos. Cada porta aberta indica a presença de um serviço ativo aguardando conexões, o que é necessário para determinadas funcionalidades. No entanto, quando essas portas permanecem abertas sem necessidade ou sem controles adequados, tornam-se potenciais pontos de entrada para ataques.

Durante a análise realizada, foram identificadas portas abertas associadas a serviços críticos, como SMB, NetBIOS, RPC, RDP (Hyper-V) e Intel AMT. Esses serviços, quando expostos, podem ser detectados facilmente por ferramentas automatizadas, permitindo que atacantes identifiquem alvos e explorem vulnerabilidades conhecidas.

Do ponto de vista dos CIS Critical Security Controls (CIS Controls), a exposição indevida de portas está diretamente relacionada à ausência de práticas adequadas de Configuração Segura (CIS 4) e Segurança de Rede (CIS 12), que recomendam a redução da superfície de ataque por meio da desativação de serviços desnecessários e restrição de acessos.

Os impactos decorrentes de portas abertas podem incluir:

Acesso não autorizado: exploração de serviços expostos para entrada no sistema ou na rede

Execução remota de código: comprometimento total do dispositivo por meio de falhas conhecidas

Movimentação lateral: propagação do ataque entre máquinas da rede local

Exposição de dados sensíveis: acesso indevido a arquivos e informações

Disseminação de malware: utilização de protocolos como SMB para espalhar ameaças

Controle remoto indevido: especialmente em serviços de gerenciamento como RDP e AMT

Além disso, quando combinadas com outras vulnerabilidades, como sistemas desatualizados (CIS 7 – Gestão de Vulnerabilidades) e controles de acesso frágeis (CIS 5 e 6 – Controle de Acessos), as portas abertas aumentam significativamente o risco de comprometimento do ambiente. A ausência de Monitoramento e Auditoria (CIS 8) dificulta ainda mais a identificação de atividades maliciosas.

Em síntese, embora necessárias para o funcionamento de determinados serviços, as portas abertas devem ser rigorosamente controladas. A aplicação dos princípios dos CIS Controls é essencial para minimizar os riscos, restringindo a exposição e garantindo maior segurança ao ambiente Windows e à rede local.

Conclusão Final

A análise de vulnerabilidades realizada no ambiente Windows e na rede local evidenciou a presença de fragilidades relevantes, principalmente relacionadas à exposição de portas abertas e à configuração inadequada da infraestrutura de rede. A identificação de serviços críticos acessíveis, como SMB, RPC, NetBIOS, RDP (Hyper-V) e Intel AMT, associada a falhas no roteador, demonstra um cenário de elevada superfície de ataque.

Do ponto de vista da perspectiva dos CIS Critical Security Controls (CIS Controls), observa-se que as vulnerabilidades identificadas estão diretamente ligadas à ausência ou implementação insuficiente de controles essenciais, como Configuração Segura (CIS 1), Controle de Acessos (CIS 5 e 6), Gestão de Vulnerabilidades (CIS 7), Monitoramento e Auditoria (CIS 8) e Segurança de Rede (CIS 12).

A combinação desses fatores aumenta significativamente o risco de exploração por agentes maliciosos, podendo resultar em acesso não autorizado, execução remota de código, movimentação lateral na rede e comprometimento de dados sensíveis. Além disso, a falta de mecanismos adequados de monitoramento dificulta a detecção e resposta a incidentes.

De forma geral, conclui-se que o ambiente apresenta vulnerabilidades comuns, porém críticas, que exigem a implementação de medidas corretivas alinhadas aos princípios dos CIS Controls. A adoção dessas práticas contribuirá para a redução da superfície de ataque, fortalecimento da segurança e aumento da resiliência do ambiente frente a ameaças.

De forma geral, o ambiente apresenta um nível de risco classificado como ALTO, demandando ações corretivas imediatas.

Evidencia Técnicas

Evidência 01 – Porta 445/tcp (SMB)

Descrição:

Durante a varredura de rede, foi identificado que a porta 445/tcp, associada ao serviço SMB (Server Message Block), encontra-se aberta no host analisado.

Resultado observado:

A ferramenta de varredura retornou status “open” para a porta 445/tcp, indicando que o serviço está ativo e acessível na rede.

Impacto:

A exposição do serviço SMB pode permitir exploração de vulnerabilidades conhecidas, acesso não autorizado a arquivos e movimentação lateral no ambiente.

Ferramenta utilizada: Nmap

Data: 24/04/2026

Evidência 02 – Porta 139/tcp (NetBIOS)

Descrição:

Durante a varredura de rede, foi identificado que a porta 139/tcp, associada ao serviço NetBIOS Session Service, encontra-se aberta no host analisado.

Resultado observado:

A ferramenta de varredura retornou status “open” para a porta 139/tcp, indicando que o serviço está ativo e acessível na rede.

Impacto:

A exposição do serviço NetBIOS pode permitir enumeração de usuários e compartilhamentos, acesso indevido a recursos da rede e exploração em ataques internos.

Ferramenta utilizada: Nmap

Data: 24/04/2026

Evidência 03 – Porta 135/tcp (MSRPC)

Descrição:

Durante a varredura de rede, foi identificado que a porta 135/tcp, associada ao serviço MSRPC (Microsoft Remote Procedure Call), encontra-se aberta no host analisado.

Resultado observado:

A ferramenta de varredura retornou status “open” para a porta 135/tcp, indicando que o serviço está ativo e acessível na rede.

Impacto:

A exposição do serviço RPC pode permitir enumeração de serviços, exploração de vulnerabilidades conhecidas e servir como vetor para ataques mais avançados.

Ferramenta utilizada: Nmap

Data: 24/04/2026

Evidência 04 – Porta 2179/tcp (RDP – Hyper-V)

Descrição:

Durante a varredura de rede, foi identificado que a porta 2179/tcp, associada ao serviço de acesso remoto a máquinas virtuais (RDP – Hyper-V), encontra-se aberta no host analisado.

Resultado observado:

A ferramenta de varredura retornou status “open” para a porta 2179/tcp, indicando que o serviço está ativo e acessível na rede.

Impacto:

A exposição desse serviço pode permitir acesso remoto não autorizado, ataques de força bruta e comprometimento de máquinas virtuais hospedadas no ambiente.

Ferramenta utilizada: Nmap

Data: 24/04/2026

Evidência 05 – Porta 16992/tcp (Intel AMT)

Descrição:

Durante a varredura de rede, foi identificado que a porta 16992/tcp, associada ao serviço Intel AMT (Active Management Technology), encontra-se aberta no host analisado.

Resultado observado:

A ferramenta de varredura retornou status “open” para a porta 16992/tcp, indicando que o serviço está ativo e acessível na rede.

Impacto:

A exposição do serviço Intel AMT pode permitir controle remoto completo da máquina, inclusive em nível de firmware, acesso indevido e comprometimento total do dispositivo.

Ferramenta utilizada: Nmap

Data: 24/04/2026

Evidência 06 – Configuração Insegura do Roteador

Descrição:

Durante a análise da rede local, foi identificado que o roteador apresenta configurações padrão e ausência de controles adequados de segurança.

Resultado observado:

Verificou-se a utilização de credenciais padrão, ausência de restrições de acesso e possível exposição de serviços, tornando a rede acessível de forma indevida.

Impacto:

Essa condição pode permitir acesso não autorizado à rede, interceptação de tráfego, exposição de dispositivos internos e comprometimento de todos os ativos conectados.

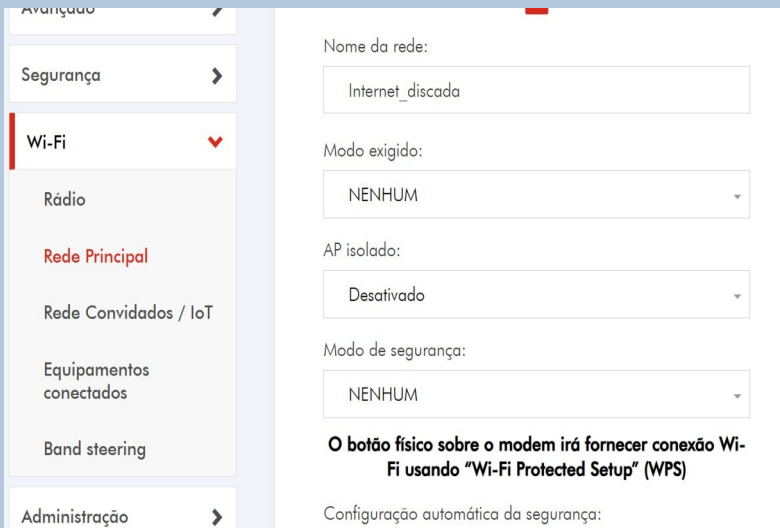
Ferramenta utilizada: Acesso direto à interface do roteador / análise manual

Data: 24/04/2026

Portas Abertas

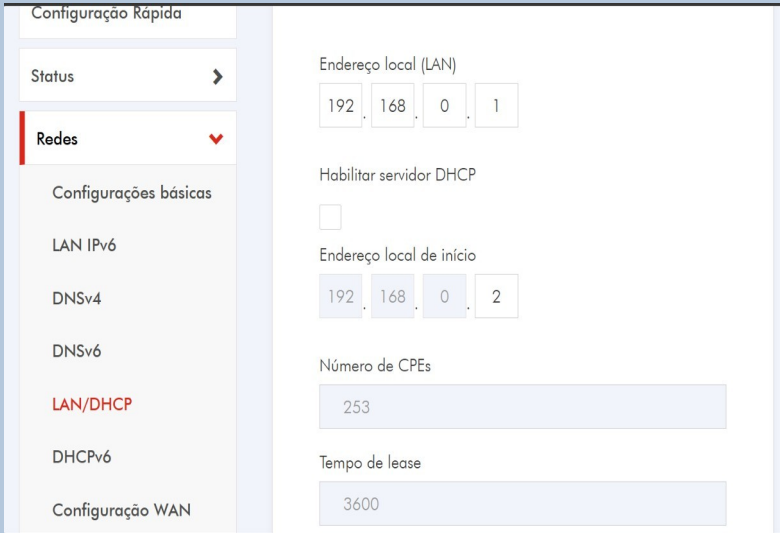
```
Sessão  Ações  Editar  Exibir  Ajuda
(apolociber@apolociber)-[~]
$ nmap -sV --version-intensity 9 [redacted]
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-24 02:34 -0300
Stats: 0:00:57 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 80.00% done; ETC: 02:35 (0:00:13 remaining)
Nmap scan report for 192.168.0.27
Host is up (0.0019s latency).
Not shown: 995 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
135/tcp    open  msrpc        Microsoft Windows RPC
139/tcp    open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds?
2179/tcp   open  vmrpd?
16992/tcp  open  http         Intel Active Management Technology User Notification Service http
d 12.0.81.1753
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows, cpe:/h:intel:active_management_techno
logy:12.0.81.1753
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 72.59 seconds
```

Evidencias de rede com configuração padrão – Baixa Segurança



1. Ausência de Criptografia (Modo de segurança: Nenhum)

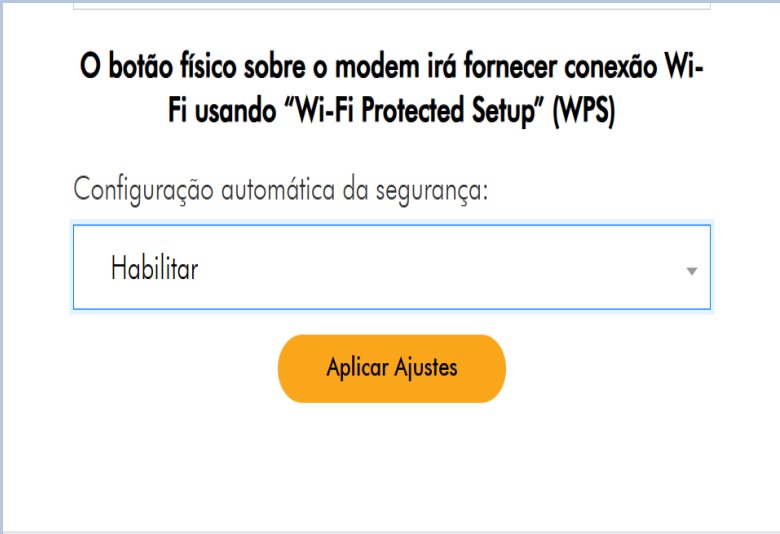
1.1 AP Isolado: Desativado



2. DHCP Desabilitado – Risco de segurança (DHCP Rogue)

2.1 Interrupção de Conexão (Risco Operacional)

2.2 Exposição via DNS



3. WPS habilitado – Risco de segurança Crítico

Habilitar	Opção
☐	Bloqueio WAN
☐	IPSEC Pass Through
☒	PPTP Pass Through
☒	Gerenciamento da Configuração Remota
☒	Multicast Ativar
☐	UPNP Ativar

Aplicar Ajustes

4. Gerenciamento de Configurações Remota (Ativado)

4.1 PPTP Pass Through (Ativado)

4.2 Multicast Ativar (Ativado)